

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 25

Domain I - Information Security Governance

27 Questions	43 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 43 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM7-001)

Which characteristic BEST distinguishes information security governance from day-to-day security management?

- A. Governance sets direction, establishes accountability, and oversees outcomes aligned with enterprise objectives.
- B. Governance focuses exclusively on technical architecture.
- C. Governance eliminates the need for business risk ownership.
- D. Governance performs every operational control activity.

Question 2 (CISM7-002)

Scenario: After a merger, one company favors formal approvals while the other relies on empowered product teams. A single rigid security process is causing delays in one business and uncontrolled exceptions in the other.

What should the information security manager recommend FIRST?

- A. Establish common risk principles with delegated authority and escalation adapted to each operating model.
- B. Require every decision to be approved by the combined board.
- C. Allow both companies to maintain unrelated governance indefinitely.
- D. Postpone governance integration until all technology platforms are merged.

Question 3 (CISM7-003)

Scenario: A telecommunications provider faces hypothetical jurisdictional, customer, and insurance notification requirements with different deadlines and materiality criteria. Separate teams currently manage each obligation.

What is the BEST governance response?

- A. Let each operational team decide materiality independently.
- B. Use the longest notification deadline for every obligation.
- C. Create an authoritative obligations map, common decision process, accountable owner, and escalation timeline.
- D. Notify every external party about every minor event.

Question 4 (CISM7-004)**What is internal audit's PRIMARY role in information security governance?**

- A. Own information security risk on behalf of business leaders
- B. Operate security controls and assess the same activities
- C. Approve routine access requests and policy exceptions
- D. Provide independent assurance on governance, risk management, and controls

Question 5 (CISM7-005)

Scenario: A security leader reports to the executive accountable for a high-profile digital launch. Material unresolved risks are removed from steering reports whenever they threaten the launch date.

Which governance response is MOST appropriate?

- A. Allow the launch executive to redefine materiality for the project.
- B. Stop documenting risks until the launch is complete.
- C. Establish direct escalation of material exposure to an independent, authorized governance forum.
- D. Require security analysts to accept the risks on behalf of the business.

Question 6 (CISM7-006)

Scenario: A local government is designing a citizen self-service capability involving identity, payments, records, applications, and external service providers. Detailed technology decisions have not been made.

What should the information security manager do now?

- A. Define risk and security requirements with business and architecture stakeholders before solution selection.
- B. Wait until penetration testing can be performed on the completed service.
- C. Assume ownership of every citizen-service process.
- D. Require the architecture to reproduce all existing manual procedures.

Question 7 (CISM7-007)

What is the PRIMARY governance value of an enterprise architecture principle?

- A. It provides consistent decision guidance while allowing authorized exceptions when justified.
- B. It specifies every detailed technology configuration.
- C. It removes the need to assess business context.
- D. It gives enterprise architects authority to accept all residual risk.

Question 8 (CISM7-008)

Scenario: A national retailer is selecting an external payroll service. The lowest-cost agreement lacks measurable recovery commitments, incident notification, assurance evidence, and support for transferring data to a replacement provider.

What should the information security manager recommend?

- A. Select the service because payroll security becomes the provider's responsibility.
- B. Require enforceable performance, notification, assurance, data handling, and exit provisions before approval.
- C. Rely on the provider's general reputation instead of contract terms.
- D. Accept the agreement and negotiate security requirements after a disruption.

Question 9 (CISM7-009)

Scenario: Infrastructure administrators can grant privileged access, change monitoring settings, and delete the logs used to review their activity.

Which control arrangement is MOST appropriate?

- A. Allow administrators to retain all permissions if they sign an annual statement.
- B. Disable privileged access outside normal working hours.
- C. Ask administrators to conduct and close their own log reviews.
- D. Protect logs independently and assign access approval and activity review to authorized roles outside administration.

Question 10 (CISM7-010)

Scenario: A diversified group proposes a shared analytics environment combining customer data from subsidiaries with different purposes, obligations, and ownership models.

What should the information security manager recommend FIRST?

- A. Establish ownership, permitted use, classification, obligations, access, and lifecycle requirements before approving the target design.
- B. Let the platform vendor define permitted uses for each subsidiary.
- C. Combine all data because a shared platform automatically reduces risk.
- D. Restrict the review to encryption technology.

Question 11 (CISM7-011)

What does the desired state describe in an information security strategy?

- A. Only the technologies already approved for purchase
- B. Every security incident that occurred in the previous year
- C. The current configuration of all enterprise devices
- D. The target capabilities and outcomes the organization intends to achieve

Question 12 (CISM7-012)

Scenario: A regional grocery chain launches online ordering while payment partners report a rise in account takeover attempts across the sector.

Why should both developments affect the information security strategy?

- A. The new channel and threat conditions change critical processes, dependencies, exposure, and capability requirements.
- B. Only the threat trend matters because online ordering is a business issue.
- C. Neither matters until the company experiences a confirmed financial loss.
- D. Payment partners should become owners of the grocery chain's strategy.

Question 13 (CISM7-013)

Scenario: A university wants consistent risk decisions across faculties. The current state has no common criteria, while the desired state assigns accountable owners and enterprise thresholds.

What should the information security manager do NEXT?

- A. Buy a risk platform before defining governance requirements.
- B. Allow each faculty to keep unrelated methods permanently.
- C. Measure success by the total number of risks recorded.
- D. Define and sequence initiatives for ownership, criteria, escalation, training, and enabling tools.

Question 14 (CISM7-014)

Scenario: A franchise network wants consistent security standards across corporate offices, small franchise locations, and outsourced distribution centers with different risk profiles.

What is the BEST approach?

- A. Allow every location to create unrelated requirements.
- B. Apply the strongest available control identically to every asset.
- C. Use only the controls supported by the oldest franchise technology.
- D. Set common mandatory outcomes and tailor implementation using risk, obligations, and operating context.

Question 15 (CISM7-015)

Scenario: A financial data company shifts toward real-time services. Available funding can support either resilience improvements required by the new model, a dashboard redesign, or replacement of a stable low-risk reporting tool.

Which initiative should receive the HIGHEST priority?

- A. The reporting tool because replacement was proposed first.
- B. The dashboard because it offers the most visible change.
- C. The resilience improvements because they enable the approved operating model and address material risk.
- D. Equal funding for all three even if no initiative can be completed.

Question 16 (CISM7-016)

Scenario: Senior leaders publicly endorse a supplier assurance strategy, but procurement goals reward only cost reduction and speed. Supplier risk reviews are repeatedly waived.

What is the PRIMARY weakness?

- A. The security team needs a larger technical toolset.
- B. Leadership incentives and decision accountability are inconsistent with the approved strategy.
- C. Procurement should have no role in supplier assurance.
- D. The strategy should exclude all objectives that affect purchasing speed.

Question 17 (CISM7-017)

Scenario: A healthcare group schedules a long-term access platform purchase before deciding whether acquired clinics will use a common identity architecture or retain local systems.

What should the information security manager recommend?

- A. Select the platform immediately to force the architecture decision.
- B. Fund separate permanent platforms for every clinic.
- C. Resolve target identity capabilities and transition dependencies before committing to the long-term investment.
- D. Exclude architects to keep security purchasing independent.

Question 18 (CISM7-018)

Scenario: A legal services company wants to reduce exposure from externally shared confidential files. It currently reports only the number of sharing-policy reminders sent.

Which measure BEST indicates achievement of the objective?

- A. The number of reminder templates
- B. The proportion of high-risk external shares corrected within the approved timeframe
- C. The number of employees receiving reminders
- D. The length of the file-sharing policy

Question 19 (CISM7-019)

Scenario: A media group acquires four companies, each with separate monitoring contracts and risk reporting. The enterprise strategy calls for shared services and consolidated oversight.

What should the information security manager do FIRST?

- A. Cancel every inherited service before replacement capabilities exist.
- B. Renew every contract for the longest term available.
- C. Map current capabilities, contracts, risks, and transition dependencies against the target operating model.
- D. Permit each company to maintain unrelated reporting indefinitely.

Question 20 (CISM7-020)

Scenario: A renewable energy operator needs industrial security expertise for a rapid expansion. Permanent hiring will take a year, but internal teams must ultimately own the capability.

Which approach is MOST appropriate?

- A. Delay all expansion security work until hiring is complete.
- B. Transfer enterprise risk acceptance to the external specialists.
- C. Use external specialists with internal accountability, defined knowledge transfer, and a transition plan.
- D. Purchase additional tools instead of developing expertise.

Question 21 (CISM7-021)

What is the PRIMARY purpose of an enterprise information security policy?

- A. To describe every detailed operational task
- B. To establish management direction, principles, authority, and mandatory expectations
- C. To replace supporting standards and procedures
- D. To record the results of individual technical tests

Question 22 (CISM7-022)

Scenario: A bank can build, buy, or jointly operate a customer fraud-detection capability. Options differ in time to value, model transparency, data exposure, skills, lifecycle cost, and exit difficulty.

How should the information security manager guide the selection?

- A. Choose the option with the largest number of technical features.
- B. Compare required outcomes, exposure, transparency, capability, total cost, oversight, and exit needs.
- C. Permit the provider to define the bank's acceptable risk.
- D. Choose the lowest initial cost without considering exit.

Question 23 (CISM7-023)

Scenario: Business leaders stop attending strategy meetings because sessions consist of technical project updates and do not identify decisions, benefits, or unresolved business risks.

What should the information security manager do?

- A. Refocus meetings on strategic outcomes, material risk, business commitments, and decisions requiring leadership.
- B. Increase the volume of technical implementation detail.
- C. Remove business leaders and invite only technical specialists.
- D. Suspend oversight until the annual budget cycle.

Question 24 (CISM7-024)

Scenario: An online broker has a low appetite for unauthorized transactions, yet its roadmap defers access governance improvements while funding lower-impact administrative reporting enhancements.

What is the BEST response?

- A. Treat risk appetite as relevant only after fraud occurs.
- B. Approve the roadmap because every initiative has some value.
- C. Reassess priorities and present the conflict with approved risk appetite to authorized decision-makers.
- D. Ask technical teams to change enterprise appetite.

Question 25 (CISM7-025)

Scenario: A security strategy remains within its three-year approval period, but two objectives are consistently missed and the enterprise has entered a new regulated market.

Why is a strategy review appropriate now?

- A. All strategies must be replaced whenever one metric changes.
- B. Performance evidence and material environmental change may invalidate priorities, assumptions, and capability needs.
- C. Approval periods prevent any interim changes.
- D. The strategy should be reviewed only when its technology budget is exhausted.

Question 26 (CISM7-026)

Scenario: A nonprofit requests funding for supplier assurance using a proposal that lists tools but does not explain risk reduction, operating ownership, or alternatives.

How should the proposal be improved?

- A. Add more product screenshots and technical terminology.
- B. Describe expected outcomes, exposure addressed, delivery alternatives, ownership, lifecycle cost, dependencies, and measures.
- C. State that security initiatives do not require financial review.
- D. Base the recommendation solely on the preferred vendor's market share.

Question 27 (CISM7-027)

Scenario: An industrial parts company launches a direct-to-consumer marketplace using external fulfillment and payment partners. Its security strategy assumes business customers, internal fulfillment, and limited personal data.

What should the information security manager do FIRST?

- A. Transfer strategy ownership to the fulfillment provider.
- B. Apply the existing strategy unchanged to preserve consistency.
- C. Purchase marketplace security tools before defining target capabilities.
- D. Reassess strategic assumptions, stakeholders, information, obligations, partner dependencies, architecture, and capability gaps.

Answer Key

Domain I - Information Security Governance

1 A	2 A	3 C	4 D	5 C
6 A	7 A	8 B	9 D	10 A
11 D	12 A	13 D	14 D	15 C
16 B	17 C	18 B	19 C	20 C
21 B	22 B	23 A	24 C	25 B
26 B	27 D			

Detailed Explanations

Question 1 (CISM7-001)

Correct answer: A - Governance sets direction, establishes accountability, and oversees outcomes aligned with enterprise objectives.

Governance provides direction, accountability, and oversight of business-aligned outcomes, while management plans and performs activities within that direction. It does not operate every control, focus only on technology, or remove the need for business risk ownership.

Question 2 (CISM7-002)

Correct answer: A - Establish common risk principles with delegated authority and escalation adapted to each operating model.

Common principles create enterprise consistency, while risk-based delegation accommodates legitimate cultural and operating differences. Permanent separation weakens oversight, board approval for every decision is impractical, and governance integration should not wait for technical consolidation.

Question 3 (CISM7-003)

Correct answer: C - Create an authoritative obligations map, common decision process, accountable owner, and escalation timeline.

An authoritative map and coordinated decision process help the provider satisfy distinct duties consistently and on time. The longest deadline may violate shorter requirements, independent decisions create inconsistency, and universal notification can breach confidentiality or create unnecessary impact.

Question 4 (CISM7-004)

Correct answer: D - Provide independent assurance on governance, risk management, and controls

Internal audit provides independent assurance over governance, risk management, and controls. Management retains risk ownership and operational approval responsibilities, while audit independence would be impaired by operating and then assessing the same controls.

Question 5 (CISM7-005)

Correct answer: C - Establish direct escalation of material exposure to an independent, authorized governance forum.

An independent escalation route ensures authorized leaders receive material risk information despite delivery conflicts. A project executive should not manipulate materiality, delayed documentation hides exposure, and analysts do not possess business risk acceptance authority.

Question 6 (CISM7-006)

Correct answer: A - Define risk and security requirements with business and architecture stakeholders before solution selection.

Early collaboration allows security needs to influence business processes, information, applications, and provider dependencies. Testing a finished service is too late for foundational choices, security does not own every process, and reproducing manual procedures may defeat the transformation.

Question 7 (CISM7-007)

Correct answer: A - It provides consistent decision guidance while allowing authorized exceptions when justified.

Architecture principles guide consistent, business-aligned decisions and support governed exceptions when circumstances justify them. They are not detailed configurations, do not replace contextual analysis, and do not transfer all risk acceptance authority to architects.

Question 8 (CISM7-008)

Correct answer: B - Require enforceable performance, notification, assurance, data handling, and exit provisions before approval.

A critical service contract needs measurable obligations, oversight rights, information handling, and exit support before commitment. Outsourcing does not transfer enterprise accountability, reputation is not enforceable assurance, and post-incident negotiation is too late.

Question 9 (CISM7-009)

Correct answer: D - Protect logs independently and assign access approval and activity review to authorized roles outside administration.

Independent log protection, approval, and review prevent administrators from concealing or authorizing their own activity. Annual statements do not remove conflicts, time restrictions may obstruct legitimate operations, and self-review provides insufficient oversight.

Question 10 (CISM7-010)

Correct answer: A - Establish ownership, permitted use, classification, obligations, access, and lifecycle requirements before approving the target design.

The architecture decision depends on business ownership, use, classification, obligations, access, and lifecycle governance. Consolidation does not automatically reduce risk, vendors do not define enterprise purposes, and encryption alone does not address the broader information governance issues.

Question 11 (CISM7-011)

Correct answer: D - The target capabilities and outcomes the organization intends to achieve

The desired state defines the target capabilities and outcomes that guide gap analysis, initiatives, and investment. Incident history and configurations help describe current conditions, while approved purchases are only possible components of a broader target state.

Question 12 (CISM7-012)

Correct answer: A - The new channel and threat conditions change critical processes, dependencies, exposure, and capability requirements.

The business channel changes assets and dependencies, while the threat trend changes external exposure; together they influence strategic capabilities and priorities. Waiting for loss is reactive, and partners do not own the enterprise's strategy.

Question 13 (CISM7-013)

Correct answer: D - Define and sequence initiatives for ownership, criteria, escalation, training, and enabling tools.

The roadmap should address the full governance capability needed to close the gap, including ownership, criteria, escalation, skills, and support tools. A tool-first approach may automate inconsistency, permanent local methods prevent the target state, and record volume does not measure decision quality.

Question 14 (CISM7-014)

Correct answer: D - Set common mandatory outcomes and tailor implementation using risk, obligations, and operating context.

Common outcomes create consistency, while risk-based implementation recognizes different environments and obligations. Unrelated requirements weaken oversight, universal maximum controls may be disproportionate, and legacy technology should not define enterprise security needs.

Question 15 (CISM7-015)

Correct answer: C - The resilience improvements because they enable the approved operating model and address material risk.

The resilience initiative directly supports the new enterprise model and treats material exposure. Visibility and proposal timing are weak criteria, while dividing insufficient funds may prevent any useful strategic outcome.

Question 16 (CISM7-016)

Correct answer: B - Leadership incentives and decision accountability are inconsistent with the approved strategy.

Sponsorship is ineffective when incentives and accountability encourage behavior contrary to the approved objective. Additional tools do not correct governance, procurement remains an essential stakeholder, and removing necessary objectives would accommodate rather than resolve the conflict.

Question 17 (CISM7-017)

Correct answer: C - Resolve target identity capabilities and transition dependencies before committing to the long-term investment.

The long-term investment should follow an agreed target capability and transition path to avoid incompatibility and stranded cost. A purchase should not force business architecture, permanent duplication undermines consolidation, and architecture input is necessary for aligned planning.

Question 18 (CISM7-018)

Correct answer: B - The proportion of high-risk external shares corrected within the approved timeframe

Timely correction of high-risk shares directly measures reduction of the intended exposure. Template and recipient counts measure activity, while policy length has no reliable relationship to the risk outcome.

Question 19 (CISM7-019)

Correct answer: C - Map current capabilities, contracts, risks, and transition dependencies against the target operating model.

A structured current-to-target assessment identifies duplication, gaps, dependencies, and necessary transition protection before investment decisions. Automatic renewal can create stranded cost, immediate cancellation creates coverage gaps, and permanent fragmentation conflicts with consolidated oversight.

Question 20 (CISM7-020)

Correct answer: C - Use external specialists with internal accountability, defined knowledge transfer, and a transition plan.

External expertise can address the immediate need while knowledge transfer and internal ownership create sustainable capability. A full delay may expose the expansion, risk authority remains internal, and tools do not replace specialized judgment.

Question 21 (CISM7-021)

Correct answer: B - To establish management direction, principles, authority, and mandatory expectations

Policy communicates management direction, governing principles, authority, and mandatory expectations. Detailed tasks belong in procedures, policy does not replace lower-level documents, and test results are operational evidence.

Question 22 (CISM7-022)

Correct answer: B - Compare required outcomes, exposure, transparency, capability, total cost, oversight, and exit needs.

A defensible sourcing decision considers strategic outcomes and full-lifecycle governance, including exposure, transparency, skills, cost, oversight, and exit. Feature count and initial price are incomplete, and a provider cannot set the bank's risk appetite.

Question 23 (CISM7-023)

Correct answer: A - Refocus meetings on strategic outcomes, material risk, business commitments, and decisions requiring leadership.

Leadership engagement is sustained when governance forums address enterprise outcomes, material risk, commitments, and decisions within leaders' authority. More technical detail reduces relevance, excluding business leaders weakens ownership, and suspending oversight delays necessary decisions.

Question 24 (CISM7-024)

Correct answer: C - Reassess priorities and present the conflict with approved risk appetite to authorized decision-makers.

The roadmap should reflect the enterprise's stated willingness to accept transaction risk, so the conflict requires transparent reprioritization. General value does not establish proper priority, appetite guides prospective decisions, and technical teams cannot redefine it.

Question 25 (CISM7-025)

Correct answer: B - Performance evidence and material environmental change may invalidate priorities, assumptions, and capability needs.

Missed objectives and a new regulated market provide evidence that assumptions, priorities, or capabilities may need adjustment before the planned cycle ends. Review does not require total replacement, approval is not a freeze, and budget exhaustion is not the sole trigger.

Question 26 (CISM7-026)

Correct answer: B - Describe expected outcomes, exposure addressed, delivery alternatives, ownership, lifecycle cost, dependencies, and measures.

A useful business case connects the investment to outcomes, risk, ownership, alternatives, costs, dependencies, and measures. Screenshots and vendor popularity do not establish enterprise value, and security investments still require appropriate financial and governance review.

Question 27 (CISM7-027)

Correct answer: D - Reassess strategic assumptions, stakeholders, information, obligations, partner dependencies, architecture, and capability gaps.

The marketplace materially changes customers, data, processes, partners, obligations, and architecture, requiring renewed strategic analysis. The old strategy is misaligned, product selection is premature, and external providers cannot own the enterprise's security strategy.